
SOC 2

Plain-Language Criteria and Audit Guide

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

The common criteria, all 33, in full.

Availability, Confidentiality, Processing Integrity, and Privacy, summarized.

Audience

Service auditors, readiness teams, control owners, and anyone who has to explain a trust services criterion to somebody who does not work in audit.

Before You Use This Document

This is a companion guide, not a copy of the standard.

The Trust Services Criteria are copyright of the AICPA. Nothing in this document reproduces their text. Every criterion here is described in original wording, using the official reference numbering as a pointer only. You still need the AICPA publication, including the points of focus and the description criteria, both of which sit outside this guide. Where this guide and the AICPA criteria appear to differ, the criteria govern. This guide is also not a substitute for professional standards; if you are issuing an opinion, those govern how you work.

What this guide does

It takes each trust services criterion and answers six questions about it, in the same order every time:

1. **What the criterion asks for.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning. The rule here matches the companion ISO/IEC 27001 guide:

Blue

Governance, communication, and risk-assessment subject matter. Tested primarily through documents, minutes, and interviews.

Orange, marked CYB

The criterion's subject matter is specifically cybersecurity, meaning it is satisfied by evidence extracted from systems rather than by inspection of governance artifacts. These are the criteria where you need technical evidence, where readiness projects consistently run out of time, and where exceptions are most often reported. Sixteen of the thirty-seven entries.

If you are planning fieldwork, the orange entries are where the hours go.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

Six things about SOC 2 that catch people out

Criteria are not controls. This is the structural difference between SOC 2 and a prescriptive framework. The criteria state required attributes; the organization designs its own controls to meet them. There is no official control list, and two service organizations can both meet CC6.1 with entirely different controls. When you audit, you are testing whether the organization's chosen controls meet the criterion, not whether they match somebody's checklist.

The period is the point. In a Type 2 you are opining on operation throughout a period, not at a date. That changes almost everything about how you test. Populations must cover the whole period. A control implemented in month eight did not operate in months one to seven, and that is an exception regardless of how good the control is now.

Establish populations yourself. The most common serious defect in SOC 2 fieldwork is sampling from a maintained list rather than from the system of record. Access grants made outside the ticketing process will not appear in the ticketing system. Production changes deployed outside the change process will not appear in the change log. Pull the population from the system that would have to record the event regardless of whether anyone followed the process, then reconcile.

Test completeness and accuracy of anything you rely on. If a control is evidenced by a system-generated report, and you rely on that report, your opinion depends on the report being complete and accurate. Document your testing of it. Reviewers look for this and its absence is a file deficiency independent of the underlying control.

Subservice organizations are where reports go wrong. Check the coverage dates of any report you rely on against your period, and check the exceptions inside it rather than accepting the overall opinion. Then check whether the complementary user entity controls it identifies have actually been implemented by your client. That last step is skipped constantly.

The report is read by customers. Unlike most audit output, a SOC 2 report is a commercial document circulated to the organization's customers and their auditors. Exceptions have commercial consequences, and the wording of your description of them will be read closely by people who were not in the room. Write accordingly.

Three definitions you need before anything else

Criterion

A required attribute of the system. Not a control. The organization designs its own controls to meet it, which is why no two SOC 2 control matrices look alike.

Deviation

An instance where a control did not operate as described. Also called an exception. Severity and pervasiveness determine whether it qualifies the opinion; a single isolated instance in a well-run control usually does not.

Complementary user entity control

A control the customer must perform for the service organization's controls to work. Usually shortened to CUEC. These place obligations on whoever reads the report, and a CUEC that was never communicated to customers cannot be relied upon.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get findings ignored: criterion numbers in the first sentence, adjectives about maturity, and recommendations that amount to "do it better." Each one names a specific consequence and, where possible, attaches a number.

One caution specific to SOC 2. This language is written for management reporting and for readiness work. It is not wording for the exceptions section of an issued report, which is governed by professional standards and by your firm's own conventions, and which is read by customers rather than by the organization. Adapt accordingly.

Contents

Before You Use This Document	ii
1 The Common Criteria: CC1 to CC9	1
CC1.1 Commitment to integrity and ethical values	3
CC1.2 Board independence and oversight	4
CC1.3 Structures, reporting lines, authorities and responsibilities	5
CC1.4 Commitment to competence	6
CC1.5 Accountability for internal control responsibilities	7
CC2.1 Obtaining and using relevant quality information	8
CC2.2 Internal communication of objectives and responsibilities	9
CC2.3 External communication	10
CC3.1 Specifying objectives	11
CC3.2 Identifying and analyzing risk	12
CC3.3 Considering the potential for fraud	13
CC3.4 Identifying and assessing changes	14
CC4.1 Ongoing and separate evaluations	15
CC4.2 Evaluating and communicating deficiencies	16
CC5.1 Selecting and developing control activities	17
CC5.2 Selecting and developing technology general controls	18
CC5.3 Deploying controls through policies and procedures	19
CC6.1 Logical access security software and infrastructure	20
CC6.2 Registration and authorization of new users	21
CC6.3 Authorizing, modifying and removing access	22
CC6.4 Restricting physical access	23
CC6.5 Discontinuing protections over disposed assets	24
CC6.6 Logical access measures against external threats	25
CC6.7 Restricting transmission, movement and removal of information	26
CC6.8 Preventing and detecting unauthorized software	27
CC7.1 Detecting configuration changes and vulnerabilities	28
CC7.2 Monitoring system components for anomalies	29
CC7.3 Evaluating security events	30
CC7.4 Responding to identified security incidents	31
CC7.5 Recovering from identified security incidents	32
CC8.1 Change management	33
CC9.1 Risk mitigation activities for business disruptions	34
CC9.2 Managing vendor and business partner risk	35
2 The Additional Categories: Availability, Confidentiality, Processing Integrity, Privacy	36
A1 Availability	37
C1 Confidentiality	39

PI1 Processing Integrity	40
P1 Privacy	41
Glossary	43
Index of Terms and Concepts	46

CHAPTER 1

The Common Criteria: CC1 to CC9

Thirty-three criteria that apply to every SOC 2 engagement, whichever trust services categories are in scope. CC1 through CC5 map to the COSO internal control framework and cover the control environment, communication, risk assessment, monitoring, and control activities. CC6 through CC9 cover access, operations, change, and risk mitigation.

Readiness projects almost always run these in the wrong order. CC6 to CC9 get the attention because they feel like security, and CC1 to CC5 get treated as paperwork to be assembled at the end. That is backwards in one specific way: CC1 to CC5 failures are systemic and cannot be remediated quickly, whereas a missing technical control can often be implemented in weeks. An absent oversight body or an unperformed risk assessment cannot be manufactured retrospectively for a period that has already closed.

Two criteria carry more weight than their length suggests. CC2.1 governs the reliability of the information every other control depends on, and it is also where your own reliance on system-generated reports gets tested. CC4.1 asks whether the organization monitors its own controls, which is the difference between an assertion based on evidence and one based on assumption.

Quick reference: the common criteria

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
CC1.1	Commitment to integrity and ethical values	Code of conduct with effective date and version
CC1.2	Board independence and oversight	Board or oversight body charter defining responsibilities
CC1.3	Structures, reporting lines, authorities and responsibilities	Organizational chart current at period end and at period start
CC1.4	Commitment to competence	Competence requirements per control-operating role
CC1.5	Accountability for internal control responsibilities	Performance objectives containing control responsibilities
CC2.1	Obtaining and using relevant quality information	Inventory of system-generated reports used in control operation
CC2.2	Internal communication of objectives and responsibilities	Policy set with publication and access evidence
CC2.3	External communication	Customer-facing documentation describing the service and control responsibilities
CC3.1	Specifying objectives	Documented objectives, service commitments, and system requirements
CC3.2	Identifying and analyzing risk	Risk assessment covering in-scope systems and processes

Ref	Title	Primary evidence
CC3.3	Considering the potential for fraud	Risk assessment sections addressing fraud
CC3.4	Identifying and assessing changes	Change records for the period across systems, vendors, and organization
CC4.1	Ongoing and separate evaluations	Monitoring programme describing activities, scope, and frequency
CC4.2	Evaluating and communicating deficiencies	Deficiency register covering all sources for the period
CC5.1	Selecting and developing control activities	Risk to control mapping in both directions
CC5.2 cyB	Selecting and developing technology general controls	Technology general control descriptions across access, change, and operations
CC5.3	Deploying controls through policies and procedures	Policy set with approval and effective dates covering the period
CC6.1 cyB	Logical access security software and infrastructure	Access architecture and network diagrams for in-scope systems
CC6.2 cyB	Registration and authorization of new users	Complete population of access grants for the period from system logs
CC6.3 cyB	Authorizing, modifying and removing access	Access review records for the period with reviewer, date, and scope
CC6.4 cyB	Restricting physical access	Facility listing distinguishing organization and subservice locations
CC6.5 cyB	Discontinuing protections over disposed assets	Disposal and sanitization procedures by media type
CC6.6 cyB	Logical access measures against external threats	External attack surface inventory with independent verification
CC6.7 cyB	Restricting transmission, movement and removal of information	Channel inventory with control coverage per channel
CC6.8 cyB	Preventing and detecting unauthorized software	Malware protection coverage and update status reports across the period
CC7.1 cyB	Detecting configuration changes and vulnerabilities	Configuration standards with their source benchmark
CC7.2 cyB	Monitoring system components for anomalies	Monitoring coverage and detection rule inventory
CC7.3 cyB	Evaluating security events	Event classification criteria and severity definitions
CC7.4 cyB	Responding to identified security incidents	Incident response programme with roles and escalation
CC7.5 cyB	Recovering from identified security incidents	Post-incident review reports with cause analysis
CC8.1 cyB	Change management	Complete population of production changes from deployment logs
CC9.1	Risk mitigation activities for business disruptions	Business impact analysis with recovery objectives
CC9.2	Managing vendor and business partner risk	Vendor register reconciled to accounts payable for the period

CC1.1 Commitment to integrity and ethical values**WHAT THE CRITERION ASKS FOR**

The organization demonstrates a commitment to integrity and ethical values. In practice this means there are stated standards of conduct, people are made aware of them, deviations are identified and addressed, and the behaviour of leadership matches what the standards say.

WHY IT EXISTS

Every other control depends on people choosing to operate them honestly. A control performed by someone willing to falsify its record is not a control. This criterion is where the auditor establishes whether the environment supports the rest of the system, which is why it sits first.

HOW TO AUDIT IT

1. Obtain the code of conduct or equivalent and confirm it addresses the behaviours relevant to the services in scope, not just general workplace conduct.
2. Verify acknowledgement across the full population including contractors, computing the rate yourself from a complete listing.
3. Test whether deviations are identified and addressed. Request the record of conduct issues in the period and what followed each.
4. Check that the process applies at all levels. Deviations handled differently by seniority is a reportable observation.
5. Look for evidence that ethical considerations feature in decisions, such as documented discussion where a commercial and an ethical consideration conflicted.
6. For a Type 2, confirm acknowledgement and any conduct processes operated throughout the period, not only at its start.

EVIDENCE TO COLLECT

- Code of conduct with effective date and version
- Acknowledgement records reconciled to a complete personnel listing covering the period
- Conduct issue records with outcomes
- Disciplinary policy covering conduct matters
- New hire onboarding materials including conduct content
- Board or management minutes evidencing ethical oversight

HOW TO DOCUMENT IT

Record acknowledgement coverage as a computed percentage with the population source and the date range. For a Type 2 this must cover the whole period, so note new joiners separately and confirm each acknowledged within a reasonable window of hire. Record conduct matters by outcome without identifying individuals.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated percentage of personnel, concentrated among contractors, have no record of acknowledging the standards of conduct that govern their handling of customer data. Give the figure and the population. For a service organization this is also a customer-facing exposure, since the report is read by customers.

CC1.2 Board independence and oversight

WHAT THE CRITERION ASKS FOR

The board of directors, or its equivalent, operates independently from management and exercises oversight of the development and performance of internal control. Independence means the oversight body can reach conclusions management would prefer it did not.

WHY IT EXISTS

Management cannot provide independent assurance over its own controls. The oversight body is the mechanism that makes management accountable to somebody. In smaller service organizations this function is frequently absent or performed by the same people it is meant to oversee, which is a real finding rather than a technicality.

HOW TO AUDIT IT

1. Identify the oversight body and establish its composition, specifically how many members are independent of management.
2. Verify it actually meets, comparing scheduled to actual meetings across the period.
3. Check that security and control matters reach it. Review minutes for evidence that control performance was presented and discussed.
4. Test whether oversight produces effect. Look for instances where the body directed action or challenged management.
5. Confirm members have sufficient information and competence to exercise oversight of technology and security matters.
6. Where no independent body exists, document how the organization achieves oversight and assess whether the alternative is adequate.

EVIDENCE TO COLLECT

- Board or oversight body charter defining responsibilities
- Membership list identifying independence status
- Meeting minutes across the period with attendance
- Materials presented on security and control performance
- Records of directions issued or challenges raised

HOW TO DOCUMENT IT

Record the independence composition as a count, and record for each period meeting whether control matters appeared on the agenda. Where oversight is nominal, evidence it with the pattern across the period rather than characterizing it, since this criterion attracts disagreement.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the body responsible for overseeing internal control has no members independent of management and did not receive any reporting on control performance during the period, so management's assertions were not subject to independent challenge.

CC1.3 Structures, reporting lines, authorities and responsibilities

WHAT THE CRITERION ASKS FOR

Management establishes, with board oversight, the structures, reporting lines, and appropriate authorities and responsibilities in pursuit of the organization's objectives. In short, it is clear who does what, who they report to, and what they are empowered to decide.

WHY IT EXISTS

Ambiguous structure produces gaps and duplication in equal measure. For a service organization the risk is specific: responsibilities relating to the services delivered to customers must be assigned to someone, or nobody is accountable for the commitments made to those customers.

HOW TO AUDIT IT

1. Obtain the organizational structure and confirm it reflects reality, comparing it to the current personnel listing.
2. Verify responsibilities relevant to the services in scope are assigned to named roles.
3. Test that role holders understand their responsibilities, by asking them rather than by reviewing the matrix.
4. Check authority accompanies responsibility, particularly for roles expected to enforce security requirements.
5. Examine segregation of incompatible duties within the structure.
6. For a Type 2, check that structural changes during the period were managed and that responsibilities were reassigned rather than lapsing.

EVIDENCE TO COLLECT

- Organizational chart current at period end and at period start
- Role descriptions containing service-relevant responsibilities
- Responsibility matrix covering in-scope services
- Records of structural changes during the period
- Delegation of authority documentation

HOW TO DOCUMENT IT

Compare assigned against understood responsibility in a two-column table from your own interviews. For a Type 2, record structural changes during the period with dates and confirm responsibilities transferred rather than lapsed, since gaps at reorganization are a common exception.

EXECUTIVE SUMMARY TREATMENT

Suggested language: responsibilities for controls supporting the services provided to customers were not reassigned following a reorganization during the period, and a stated number of control activities went unperformed as a result. Give the duration of the gap.

CC1.4 Commitment to competence

WHAT THE CRITERION ASKS FOR

The organization demonstrates a commitment to attract, develop, and retain competent individuals in alignment with its objectives. This covers hiring practices, training, evaluation, and whether the organization can keep the people it needs.

WHY IT EXISTS

Controls are operated by people, and a control operated by someone who does not understand it produces evidence without assurance. Retention matters as much as recruitment for a service organization, because turnover in control-operating roles creates repeated periods of reduced control effectiveness.

HOW TO AUDIT IT

1. Obtain competence requirements for roles operating in-scope controls, and confirm they exist rather than being inferred from job titles.
2. Sample personnel and compare held qualifications, training, and experience against the requirement.
3. Verify background screening was performed before access was granted, comparing screening completion to start and access dates.
4. Review training completion for control operators, including role-specific training rather than only general awareness.
5. Examine turnover in control-operating roles across the period and whether it affected control performance.
6. Check contractors and outsourced personnel, whose competence evidence is frequently absent.

EVIDENCE TO COLLECT

- Competence requirements per control-operating role
- Personnel files evidencing qualifications and experience for the sample
- Background screening records with completion dates
- Training completion records for the period
- Turnover data for control-operating roles
- Contractor competence or supplier attestation evidence

HOW TO DOCUMENT IT

Present the sample as a table of role, required competence, evidence held, and conclusion, with population and selection method stated. Record screening completion against access grant dates, since access preceding screening is a discrete exception that this criterion covers.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of personnel were granted access to systems processing customer data before their background screening completed, and contractors operating controls have no competence evidence at all. Give counts and separate the two populations.

CC1.5 Accountability for internal control responsibilities**WHAT THE CRITERION ASKS FOR**

The organization holds individuals accountable for their internal control responsibilities. Accountability means performance against those responsibilities is measured, and that failing to meet them has a consequence.

WHY IT EXISTS

Responsibility without accountability produces controls that are performed when convenient. For a Type 2 engagement this matters directly: the auditor is testing whether controls operated consistently across a period, and consistency depends on someone caring whether they did.

HOW TO AUDIT IT

1. Check whether control responsibilities appear in performance objectives or equivalent for the people who operate them.
2. Verify performance against control responsibilities is actually evaluated, by reviewing completed evaluations.
3. Test whether failure to perform a control has a consequence, by examining instances where controls were not performed and what followed.
4. Look for monitoring of control performance by supervisors, distinct from the formal evaluation cycle.
5. Check that accountability extends to management, not only to individual contributors.
6. For a Type 2, look for controls performed late or missed during the period and how those were handled.

EVIDENCE TO COLLECT

- Performance objectives containing control responsibilities
- Completed performance evaluations for sampled control operators
- Records of controls not performed and the response
- Supervisory review records for control performance
- Escalation records where control performance was inadequate

HOW TO DOCUMENT IT

List instances during the period where a control was not performed on time, with what followed each. That list is the evidence for this criterion, and its absence where you have separately identified missed controls is itself the finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: controls were not performed on a stated number of occasions during the period with no consequence for the individuals responsible, and control performance does not feature in any performance evaluation. Give the count.

CC2.1 Obtaining and using relevant quality information

WHAT THE CRITERION ASKS FOR

The organization obtains or generates and uses relevant, quality information to support the functioning of internal control. The information has to be accurate, complete, timely, and actually used rather than merely produced.

WHY IT EXISTS

Controls that depend on information inherit that information's defects. A monitoring control reviewing an incomplete log will report that nothing happened. This criterion is where the auditor tests the reliability of the data the rest of the control environment runs on, which is why it is often underestimated.

HOW TO AUDIT IT

1. Identify the information sources that controls depend on, particularly system-generated reports used in control operation.
2. Test the completeness and accuracy of key reports rather than accepting them. Reconcile a report to its source or reproduce it independently.
3. Check whether report parameters could exclude relevant records, which is the most common way a report misleads without being wrong.
4. Verify information reaches the control operator in time to be useful.
5. Check that the organization has itself considered the reliability of the information its controls depend on.
6. For any report you rely on as audit evidence, document your own completeness and accuracy testing, since your opinion depends on it too.

EVIDENCE TO COLLECT

- Inventory of system-generated reports used in control operation
- Report parameters and query definitions
- Source data extracts for reconciliation
- Evidence of the organization's own completeness and accuracy testing
- Timeliness evidence such as report generation and review dates

HOW TO DOCUMENT IT

Document your completeness and accuracy testing for each report you relied on: the report, the parameters, the reconciliation performed, and the result. This is a documentation requirement for your own file as much as a test of the criterion, and reviewers will look for it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the reports used to operate and evidence key controls exclude records matching a stated condition, so the controls have been operating on incomplete information throughout the period. Name the report and the exclusion.

CC2.2 Internal communication of objectives and responsibilities**WHAT THE CRITERION ASKS FOR**

The organization internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control. People must know what they are responsible for and how to raise problems.

WHY IT EXISTS

Controls fail silently when the person operating them does not understand the objective. This criterion also covers the internal reporting channel, which is how control failures reach the people who can address them. A service organization with no route for staff to report a problem will learn about problems from its customers.

HOW TO AUDIT IT

1. Verify security and control responsibilities are communicated to personnel, and test by asking rather than by reviewing distribution records.
2. Check that policies relevant to in-scope services are available and that staff can locate them.
3. Examine the internal channel for reporting control failures or security concerns, including whether it is known and used.
4. Review reporting volumes across the period. Very low volumes indicate a channel nobody uses.
5. Check that changes affecting controls were communicated to the people operating them during the period.
6. Verify communication reaches contractors and temporary staff operating in-scope controls.

EVIDENCE TO COLLECT

- Policy set with publication and access evidence
- Communication records: onboarding, all-hands, targeted notices with dates
- Internal reporting channel description and volume statistics
- Sample reports raised with outcomes
- Change communications issued during the period

HOW TO DOCUMENT IT

Record interview responses on both responsibilities and reporting routes. Present reporting channel volumes across the period, since a channel that received nothing across twelve months is either unknown or distrusted and both are reportable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personnel operating key controls could not describe the objective those controls serve, and the internal channel for reporting control failures received no reports during the period. The second figure is usually more persuasive than any description of communication quality.

CC2.3 External communication

WHAT THE CRITERION ASKS FOR

The organization communicates with external parties regarding matters affecting the functioning of internal control. For a service organization this includes what customers are told about the service, about their own responsibilities, and about incidents affecting them.

WHY IT EXISTS

Service organizations depend on customers performing certain controls themselves, and those expectations only work if the customer knows about them. This criterion also covers incident communication, which is where a service organization's failure becomes its customers' problem.

HOW TO AUDIT IT

1. Identify what the organization communicates to customers about the service and its controls.
2. Verify complementary user entity controls are communicated to customers, since these are obligations the organization is relying on customers to perform.
3. Check the incident communication process and test it against any incident during the period, comparing actual notification to contractual commitments.
4. Examine communication with vendors and subservice organizations regarding control expectations.
5. Check that customer-facing commitments about security are accurate and supportable.
6. Verify a channel exists for customers to raise concerns and that it is responsive.

EVIDENCE TO COLLECT

- Customer-facing documentation describing the service and control responsibilities
- Complementary user entity control communications
- Incident notification records with dates against contractual timeframes
- Customer agreements containing security commitments
- Vendor communications regarding control expectations
- Customer concern channel and response records

HOW TO DOCUMENT IT

Record whether complementary user entity controls are communicated to customers and by what mechanism, since a CUEC the customer has never been told about cannot be relied on and affects the report's usefulness. For incidents, record notification timing against the contractual requirement.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization relies on customers performing a stated number of controls that it has never communicated to them, so those controls cannot be assumed to operate. This directly affects the assurance the report provides and should be raised early.

CC3.1 Specifying objectives

WHAT THE CRITERION ASKS FOR

The organization specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to those objectives. Objectives must be specific enough that you can tell what would threaten them.

WHY IT EXISTS

Risk is defined relative to an objective. Without clear objectives, risk identification has no reference point and produces a generic list. For a service organization the objectives include the service commitments and system requirements it has made to customers, which is what the whole report is about.

HOW TO AUDIT IT

1. Obtain the documented objectives, including the service commitments and system requirements relevant to the criteria in scope.
2. Assess specificity. Objectives must be concrete enough to identify what would prevent their achievement.
3. Verify objectives reflect actual customer commitments, by comparing them to a sample of customer agreements and service level commitments.
4. Check that objectives cover each trust services category in scope.
5. Confirm objectives are approved and reviewed.
6. Verify objectives were the basis for the risk assessment, by tracing forward.

EVIDENCE TO COLLECT

- Documented objectives, service commitments, and system requirements
- Customer agreements and service level commitments for comparison
- Approval records for objectives
- Risk assessment showing objectives as inputs
- Review records for objectives

HOW TO DOCUMENT IT

Compare documented objectives against commitments in sampled customer agreements and record any commitment not reflected in an objective. Those are commitments the risk assessment never considered, which is a defensible and specific finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: commitments made to customers in service agreements are not reflected in the organization's stated objectives, so the risks to meeting those commitments were never assessed. Name the commitments.

CC3.2 Identifying and analyzing risk

WHAT THE CRITERION ASKS FOR

The organization identifies risks to the achievement of its objectives and analyzes those risks as a basis for determining how they should be managed. Identification covers the whole entity and analysis covers likelihood and impact.

WHY IT EXISTS

The risk assessment is what justifies the control set. Without it, controls exist because somebody thought of them rather than because they address an assessed risk, and there is no basis for concluding the set is complete.

HOW TO AUDIT IT

1. Obtain the risk assessment and confirm it covers the systems and processes supporting the in-scope services.
2. Verify risks are analyzed rather than only listed, with likelihood and impact reasoning recorded.
3. Check that identified risks map to controls, and that the mapping is complete in both directions.
4. Test coverage by identifying a risk yourself that the assessment omits, using the system description and your knowledge of the environment.
5. Confirm the assessment was performed or updated during the period.
6. Check that risk acceptance decisions were made by someone with authority.

EVIDENCE TO COLLECT

- Risk assessment covering in-scope systems and processes
- Risk to control mapping
- Analysis showing likelihood and impact reasoning
- Evidence of assessment performance during the period with dates
- Risk acceptance approvals

HOW TO DOCUMENT IT

Record any risk you identified that the assessment omits, with your reasoning. Identifying an omission independently is far stronger evidence than observing that the methodology is weak. Record the assessment date within the period.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the risk assessment does not address a named risk that is material to the services provided, and was not updated during the period despite significant changes to the environment. Name the omission and the changes.

CC3.3 Considering the potential for fraud

WHAT THE CRITERION ASKS FOR

The organization considers the potential for fraud in assessing risks to the achievement of objectives. Fraud here includes fraudulent reporting, misappropriation of assets, and corruption, and covers fraud by personnel as well as by outsiders.

WHY IT EXISTS

Fraud risk is different from error risk because it involves deliberate concealment, which means controls designed to catch mistakes will not catch it. Considering fraud explicitly is what surfaces the need for segregation of duties and independent review rather than simply more checking.

HOW TO AUDIT IT

1. Verify fraud is considered explicitly in the risk assessment rather than assumed to be covered.
2. Check the consideration addresses fraud by insiders, including those operating controls.
3. Look for identification of incentives, opportunities, and rationalizations rather than a general acknowledgement that fraud is possible.
4. Verify that identified fraud risks map to specific controls, typically segregation of duties, independent review, and monitoring.
5. Check whether privileged access was considered as a fraud opportunity, since privileged users can conceal their own activity.
6. Confirm any fraud or suspected fraud during the period was considered in the assessment.

EVIDENCE TO COLLECT

- Risk assessment sections addressing fraud
- Fraud risk identification covering incentive, opportunity, and rationalization
- Controls mapped to identified fraud risks
- Segregation of duties analysis
- Records of any fraud or suspected fraud during the period

HOW TO DOCUMENT IT

Record whether fraud consideration is substantive or a single acknowledging sentence, quoting what is there. Note specifically whether insider fraud by privileged users was considered, since that is the fraud scenario most relevant to a service organization and most often absent.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the risk assessment does not consider the potential for fraud by personnel with privileged system access, who are able to both perform and conceal unauthorized activity. This is the fraud scenario most relevant to the services in scope.

CC3.4 Identifying and assessing changes

WHAT THE CRITERION ASKS FOR

The organization identifies and assesses changes that could significantly impact the system of internal control. Changes include changes to the business, to systems, to personnel, to vendors, and to the regulatory environment.

WHY IT EXISTS

Control systems are designed for a set of circumstances and degrade when those circumstances change. A control designed around a system that has since been replaced may still be performed and no longer achieve anything. For a Type 2 covering a period, changes during that period are directly in scope.

HOW TO AUDIT IT

1. Identify significant changes during the period independently, using change records, project lists, vendor communications, and organizational announcements.
2. Verify each was assessed for impact on internal control.
3. Check that the assessment resulted in control changes where needed, and that new controls were implemented and operating.
4. Examine changes in subservice organizations, which are frequently unmonitored.
5. Check personnel changes affecting control operation, particularly departures of sole control operators.
6. Verify regulatory or commitment changes were assessed.

EVIDENCE TO COLLECT

- Change records for the period across systems, vendors, and organization
- Impact assessments for identified changes
- Control modifications arising from changes
- Subservice organization change notifications
- Personnel change records for control-operating roles

HOW TO DOCUMENT IT

Compile the change list independently rather than accepting the organization's, and present your list against whether each was assessed. For a Type 2 this also determines whether controls were consistent across the period or changed partway through, which affects how you describe your testing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a named significant change during the period was implemented without assessing its effect on internal control, and controls that depended on the prior arrangement continued to be performed without achieving their objective.

CC4.1 Ongoing and separate evaluations

WHAT THE CRITERION ASKS FOR

The organization selects, develops, and performs ongoing and separate evaluations to ascertain whether the components of internal control are present and functioning. Ongoing evaluation is built into operations; separate evaluation is periodic and independent, such as internal audit.

WHY IT EXISTS

Controls degrade without anyone deciding to let them. Monitoring is the organization's own mechanism for detecting that, and it is what allows management to make its assertion honestly. A service organization with no monitoring is asserting control effectiveness on the basis of assumption.

HOW TO AUDIT IT

1. Identify the monitoring activities performed, distinguishing ongoing from separate evaluations.
2. Verify monitoring covers the controls relevant to the criteria in scope, and identify controls subject to no monitoring.
3. Check the independence of separate evaluations. Self-assessment by the control operator is not a separate evaluation.
4. Test monitoring quality by re-performing a sampled monitoring activity and comparing your result to the recorded one.
5. Verify monitoring occurred throughout the period at the stated frequency.
6. Check that monitoring uses reliable information, linking to CC2.1.

EVIDENCE TO COLLECT

- Monitoring programme describing activities, scope, and frequency
- Completed monitoring records across the period with dates and performers
- Independence evidence for separate evaluations
- Internal audit reports if applicable
- Coverage mapping of monitoring to controls

HOW TO DOCUMENT IT

Record your re-performance of a sampled monitoring activity against the organization's recorded result. A discrepancy undermines the reliability of the monitoring programme generally and is worth more than several observations about its design. Present coverage as controls monitored against total.

EXECUTIVE SUMMARY TREATMENT

Suggested language: monitoring of control effectiveness is performed by the same personnel who operate the controls, and independent re-performance found results that differ from those recorded. Management's assertion therefore rests on self-assessment that could not be substantiated.

CC4.2 Evaluating and communicating deficiencies

WHAT THE CRITERION ASKS FOR

The organization evaluates and communicates internal control deficiencies in a timely manner to those responsible for taking corrective action, including senior management and the board where appropriate.

WHY IT EXISTS

Finding a deficiency achieves nothing if it does not reach someone who will fix it. Timeliness matters because a deficiency communicated after the period has already had its effect. This criterion is also where the auditor establishes whether known problems were disclosed or suppressed.

HOW TO AUDIT IT

1. Obtain the record of deficiencies identified during the period from all sources: monitoring, internal audit, incidents, and self-identification.
2. Verify each was evaluated for severity and communicated to someone able to act.
3. Check timeliness by measuring the interval between identification and communication.
4. Verify significant deficiencies reached senior management and the oversight body.
5. Track remediation to completion and identify deficiencies open at period end.
6. Compare the organization's deficiency record against deficiencies you identified independently, since undisclosed known issues are a serious matter.

EVIDENCE TO COLLECT

- Deficiency register covering all sources for the period
- Severity evaluations and communication records with dates
- Escalation records to senior management and the board
- Remediation tracking with status at period end
- Monitoring and audit outputs for comparison

HOW TO DOCUMENT IT

Compare deficiencies you identified against those on the organization's register, and record any that were known internally but not recorded. Present remediation as an aging analysis of items open at period end. Both feed directly into your assessment of whether exceptions should be reported.

EXECUTIVE SUMMARY TREATMENT

Suggested language: control deficiencies identified during the period were not communicated to management, and a stated number remained unremediated at period end, the oldest identified a stated number of months earlier. Give the counts and the aging.

CC5.1 Selecting and developing control activities

WHAT THE CRITERION ASKS FOR

The organization selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels. The controls must address the assessed risks and be appropriate to the circumstances.

WHY IT EXISTS

This is the criterion that connects the risk assessment to the control set. It is where the auditor tests whether the controls in the system description were chosen for a reason, and whether the set is complete relative to the risks identified.

HOW TO AUDIT IT

1. Trace from the risk assessment to the control set and confirm each significant risk has one or more controls addressing it.
2. Trace in the other direction and confirm controls exist for a reason rather than by inheritance from a template.
3. Assess whether the control mix includes preventive and detective controls appropriately, since a set consisting only of detective controls accepts that failures will occur.
4. Check that controls are at the right level. A control operating annually against a risk that materializes daily provides limited mitigation.
5. Verify controls were selected considering the specific circumstances, including reliance on subservice organizations.
6. Check that control selection is documented rather than implicit.

EVIDENCE TO COLLECT

- Risk to control mapping in both directions
- Control descriptions with frequency and type
- Documentation of control selection rationale
- Subservice organization reliance analysis
- Control matrix supporting the system description

HOW TO DOCUMENT IT

Present the risk to control mapping with any unmatched risks identified. Record control frequency against risk velocity where there is a mismatch, since that is a design observation the organization can act on and it is often overlooked.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of risks the organization identified have no corresponding control, and the control set relies predominantly on detection after the fact rather than prevention. Name the unmitigated risks.

CC5.2 Selecting and developing technology general controls

WHAT THE CRITERION ASKS FOR

The organization selects and develops general control activities over technology to support the achievement of objectives. These are the controls over the technology environment itself: access, change, and operations, on which application controls depend.

WHY IT EXISTS

Application controls are only as reliable as the technology environment beneath them. An automated control can be bypassed, disabled, or altered by anyone with sufficient access to the underlying system, which means access and change controls determine whether every automated control in the system description can be relied on.

HOW TO AUDIT IT

1. Identify the technology general controls in place across access, change, and operations.
2. Assess coverage against the systems supporting the in-scope services, including infrastructure, databases, and cloud platforms, not just applications.
3. Check that general controls cover the environments where automated controls could be altered.
4. Verify the relationship between general controls and the automated controls that depend on them is understood.
5. Examine privileged access to systems hosting automated controls, since that access can defeat them.
6. Check technology general controls at subservice organizations where in-scope systems are hosted.

EVIDENCE TO COLLECT

- Technology general control descriptions across access, change, and operations
- System inventory supporting in-scope services
- Privileged access listings for systems hosting automated controls
- Dependency analysis between general and automated controls
- Subservice organization control reports covering hosted environments

HOW TO DOCUMENT IT

Record which automated controls depend on which general controls, since a general control deficiency propagates to every automated control beneath it and that propagation determines the severity of your finding. Note gaps in general control coverage by system.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personnel hold administrative access to the systems hosting the organization's automated controls, meaning those controls could be altered or disabled without detection. This affects the reliability of every automated control in the description and should be reported as such.

CC5.3 Deploying controls through policies and procedures**WHAT THE CRITERION ASKS FOR**

The organization deploys control activities through policies that establish what is expected and procedures that put those policies into action. Policies state the requirement; procedures state how it is carried out and by whom.

WHY IT EXISTS

A control that exists only as practice depends on the memory of whoever performs it and stops when they leave. Documented procedures make controls repeatable and transferable, and they are what allows an auditor to determine whether a control operated as designed rather than as improvised.

HOW TO AUDIT IT

1. Verify policies exist covering the areas relevant to the criteria in scope, with approval and effective dates.
2. Check that procedures exist beneath the policies and are specific enough to be followed by a competent person unfamiliar with the task.
3. Test whether procedures match practice, by observing or walking through a control and comparing to the documented procedure.
4. Verify procedures identify who performs the control and how often.
5. Check that policies and procedures were current throughout the period, and that changes were controlled.
6. Confirm procedures are available to the people who need them.

EVIDENCE TO COLLECT

- Policy set with approval and effective dates covering the period
- Procedures for controls in the system description
- Walkthrough records comparing procedure to practice
- Policy and procedure revision history for the period
- Access and availability evidence

HOW TO DOCUMENT IT

Record divergences between documented procedure and observed practice side by side. Where practice is sound but undocumented, say so explicitly, since the remediation differs from the case where practice is wrong. Confirm policy currency across the whole period for a Type 2, not just at period end.

EXECUTIVE SUMMARY TREATMENT

Suggested language: key controls are performed according to individual practice rather than documented procedure, so their consistent operation depends on specific individuals and could not be sustained if those individuals left. Name the controls and the number of people who can perform each.

CC6.1 Logical access security software and infrastructure

WHAT THE CRITERION ASKS FOR

The organization implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events. This is the foundational access criterion covering how access is architected and enforced technically.

WHY IT EXISTS

Access is the mechanism through which nearly every security failure is realized. The scope of any compromise is bounded by what the compromised identity could reach. For a service organization this also determines whether one customer's data is reachable from another's context, which is the question customers care about most.

HOW TO AUDIT IT

1. Obtain the access architecture and identify the mechanisms enforcing access across each in-scope system.
2. Verify least privilege in practice by extracting permissions yourself and comparing them to role requirements for a sample of users.
3. Test tenant or customer separation where the service is multi-tenant, since this is the highest-consequence access question for a service organization.
4. Examine authentication requirements, including multi-factor coverage and any accounts exempt from it.
5. Check encryption of data at rest and in transit where the criteria in scope require it.
6. Identify shared and service accounts and confirm accountability for each.
7. For a Type 2, confirm the architecture was in place throughout the period rather than implemented partway through.

EVIDENCE TO COLLECT

- Access architecture and network diagrams for in-scope systems
- Permission extracts from each in-scope system, taken by the auditor
- Multi-factor authentication coverage with exception listing
- Encryption configuration evidence
- Tenant separation design and test evidence
- Shared and service account register with owners

HOW TO DOCUMENT IT

Extract permissions yourself rather than accepting a report, and record the extraction method and date. Present the least privilege test as user, role, permissions held, permissions justified, and excess. For multi-tenant services, record the separation test specifically, since it is the finding customers read the report for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of personnel hold access beyond their role requirements, and administrative access to systems processing customer data is not protected by multi-factor authentication. Give counts and the ratio of privileged accounts to total users.

CC6.2 Registration and authorization of new users**WHAT THE CRITERION ASKS FOR**

Prior to issuing system credentials and granting system access, the organization registers and authorizes new internal and external users whose access is administered by the organization. Access is removed when no longer required.

WHY IT EXISTS

Access granted without authorization has no basis, and nobody can later say whether it was appropriate. This criterion is heavily tested in Type 2 engagements because it produces a clean population: every access grant during the period should have an authorization behind it.

HOW TO AUDIT IT

1. Obtain the complete population of access grants during the period and verify its completeness against system logs rather than a maintained list.
2. Sample grants and verify each had documented authorization from someone with authority, before access was provisioned.
3. Check that the authorizer is independent of the requester. Self-authorization is a common exception.
4. Verify external users, including customer and vendor personnel, are covered by the same process.
5. Test the removal side by sampling terminations and measuring the interval to access revocation across all in-scope systems.
6. Check for access granted with no corresponding request at all, which is the more serious version of this exception.

EVIDENCE TO COLLECT

- Complete population of access grants for the period from system logs
- Access request and approval records for sampled grants
- Authorization matrix defining who may approve what
- Termination listing from human resources for the period
- Revocation timestamps per system for sampled terminations

HOW TO DOCUMENT IT

Establish the population from system logs and reconcile it to the ticketing record, since grants made outside the process will not appear in the ticket system. Present terminations with revocation intervals per system, because the aggregate figure hides the outlying system that stays open.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of access grants during the period had no authorization, and access for departing personnel remained active for an average of a stated number of days, up to a maximum of a stated number, including systems holding customer data.

CC6.3 Authorizing, modifying and removing access

WHAT THE CRITERION ASKS FOR

The organization authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design, and considering the concepts of least privilege and segregation of duties. Access is reviewed periodically.

WHY IT EXISTS

Access granted correctly still becomes wrong as people change roles. Periodic review is the only mechanism that catches accumulation. This criterion is where the auditor tests whether reviews are substantive or ceremonial, and the answer is usually visible from the revocation rate alone.

HOW TO AUDIT IT

1. Verify access reviews were performed at the stated frequency during the period, with dates.
2. Test review quality rather than occurrence. Compare a completed review to the underlying permissions and check whether anything was revoked.
3. Calculate the revocation rate: permissions reviewed against permissions removed. A rate at or near zero across a large population indicates a rubber stamp.
4. Verify reviewers had the knowledge to assess appropriateness. A reviewer approving access to systems they do not understand adds nothing.
5. Test role changes specifically, confirming prior access was removed rather than only new access added.
6. Check that segregation of duties conflicts are identified during review.
7. Confirm review scope covers all in-scope systems, including those outside the central identity platform.

EVIDENCE TO COLLECT

- Access review records for the period with reviewer, date, and scope
- Revocation counts arising from reviews
- Permission extracts corresponding to a completed review for re-performance
- Role change records with before and after permission states
- Segregation of duties conflict matrix and review output
- System listing showing review scope coverage

HOW TO DOCUMENT IT

Report the revocation rate as a computed figure with the population, since it is the single most effective evidence of review quality and is difficult to dispute. Re-perform one review against the underlying data and record the items you would have questioned that the reviewer approved.

EXECUTIVE SUMMARY TREATMENT

Suggested language: access reviews were completed on schedule throughout the period but resulted in no revocations across a stated number of accounts reviewed, and independent re-performance identified a stated number of users holding access inappropriate to their role.

CC6.4 Restricting physical access

WHAT THE CRITERION ASKS FOR

The organization restricts physical access to facilities and protected information assets to authorized personnel, commensurate with the assessed risk. This covers offices, data centres, and any location where in-scope assets are held.

WHY IT EXISTS

Physical access defeats logical controls. Where the organization hosts its own infrastructure this is directly in scope; where it uses a cloud provider, the criterion shifts to the provider and the organization's own offices, and the auditor must be clear which is which.

HOW TO AUDIT IT

1. Establish which facilities are in scope, distinguishing organization-controlled locations from subservice organization facilities.
2. For organization-controlled facilities, obtain the access authorization list and assess whether every holder still requires access.
3. Verify physical access is revoked on termination, reconciling the badge listing to the leaver listing.
4. Review physical access logs for the period and check whether they are monitored or only retained.
5. Perform a walkthrough outside core hours where practical, recording date, time, and location for every observation.
6. For subservice organization facilities, obtain and review their report and confirm the physical controls are covered by it.

EVIDENCE TO COLLECT

- Facility listing distinguishing organization and subservice locations
- Physical access authorization lists with justification
- Badge system access logs for the period
- Termination listing reconciled to badge revocation dates
- Walkthrough observations with date, time, and location
- Subservice organization reports covering physical controls

HOW TO DOCUMENT IT

Be explicit about which facilities are the organization's responsibility and which are carved out to a subservice organization, since misattributing this is a common error that undermines the whole criterion. Record badge revocation intervals for terminations.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of former personnel retained active building access to facilities containing systems that process customer data, the oldest for a stated period after their departure.

CC6.5 Discontinuing protections over disposed assets**WHAT THE CRITERION ASKS FOR**

The organization discontinues logical and physical protections over physical assets only after the ability to read or recover data has been diminished and is no longer required to meet objectives. In practice: data is removed before equipment leaves organizational control.

WHY IT EXISTS

Disposed equipment leaves permanently and standard deletion does not remove data. The requirement is to verify removal rather than instruct it, because an unverified erasure is an assumption. Re-use within the organization is covered too and is usually less controlled than disposal.

HOW TO AUDIT IT

1. Obtain the disposal procedure and confirm it specifies a sanitization method appropriate to the media type.
2. Verify the verification step exists and is performed by someone other than the person who erased the media.
3. Reconcile the asset inventory to disposal records across the period and identify assets that left without a record.
4. For third-party disposal, confirm certificates identify assets by serial number rather than by quantity.
5. Check the re-use path, which is frequently handled informally.
6. Examine the security of equipment awaiting disposal.

EVIDENCE TO COLLECT

- Disposal and sanitization procedures by media type
- Asset inventory reconciled to disposal records for the period
- Destruction certificates listing serial numbers
- Third-party disposal provider contract and certification
- Re-use records showing sanitization before reassignment

HOW TO DOCUMENT IT

Present the reconciliation as assets in service at period start, acquired, disposed with records, and the unexplained difference. Record whether certificates identify individual assets, since a certificate for a quantity proves nothing about any specific device.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices left the asset inventory during the period with no disposal record, so the organization cannot demonstrate that customer data they held was destroyed.

CC6.6 Logical access measures against external threats

WHAT THE CRITERION ASKS FOR

The organization implements logical access security measures to protect against threats from sources outside its system boundaries. This covers the perimeter in its broadest sense: network controls, external authentication, and protection of externally reachable services.

WHY IT EXISTS

External attack is the threat customers most expect a SOC 2 report to address. The criterion focuses on what is reachable from outside and how it is protected, which for most modern service organizations means internet-facing applications and interfaces rather than a network perimeter.

HOW TO AUDIT IT

1. Identify everything externally reachable, using external scanning or the organization's own attack surface inventory, and verify completeness.
2. Check protective measures on each: authentication, rate limiting, filtering, and inspection.
3. Verify external authentication requires multi-factor for administrative and remote access.
4. Examine external network controls and rule sets, looking for permissive rules and their age.
5. Check protection of application interfaces, including authentication and authorization on programmatic access.
6. Review external penetration testing performed during the period, including findings and their remediation status.
7. Verify measures operated throughout the period, not only at a point in time.

EVIDENCE TO COLLECT

- External attack surface inventory with independent verification
- Firewall and network control rule sets with review records
- Authentication configuration for externally reachable services
- Penetration test reports covering the period with remediation evidence
- Rate limiting and filtering configuration
- Change records for perimeter controls during the period

HOW TO DOCUMENT IT

Verify the attack surface inventory independently rather than accepting it, and record anything you found that was not on it. Report penetration test findings against remediation status with the age of open items, since unremediated findings from a test the organization commissioned are difficult to defend.

EXECUTIVE SUMMARY TREATMENT

Suggested language: penetration testing commissioned by the organization identified a stated number of high severity findings that remained unremediated at period end, the oldest for a stated number of months, and a stated number of externally reachable services were absent from the organization's own inventory.

CC6.7 Restricting transmission, movement and removal of information**WHAT THE CRITERION ASKS FOR**

The organization restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal.

WHY IT EXISTS

Information is most exposed while moving, and movement is the point at which control passes to someone else. This criterion covers both the authorization to move information and its protection while moving, and it extends to removable media and endpoint egress as well as network transmission.

HOW TO AUDIT IT

1. Identify the channels through which in-scope information can leave and confirm the inventory is complete, including unsanctioned channels.
2. Verify encryption in transit is enforced rather than available, by checking configuration rather than policy.
3. Check controls over removable media and test whether they are enforced, with authorization.
4. Examine authorization requirements for transferring information externally.
5. Check egress controls at the endpoint, since network controls do not cover remote workers.
6. Review any data loss detection in place and whether its alerts are investigated.

EVIDENCE TO COLLECT

- Channel inventory with control coverage per channel
- Encryption in transit configuration evidence
- Removable media control configuration and test results
- Authorization records for external transfers
- Endpoint egress control coverage
- Detection alert volumes and investigation records

HOW TO DOCUMENT IT

List channels against coverage in a table; uncovered channels are the finding and the gap is obvious once laid out. Where you tested removable media control practically, record the test and result, since configuration frequently reports controls that are not actually enforced.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer information can be copied to removable media or uploaded to external services from any workstation without restriction or record, and the organization has no capability to detect it.

CC6.8 Preventing and detecting unauthorized software**WHAT THE CRITERION ASKS FOR**

The organization implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software.

WHY IT EXISTS

Malicious software is the delivery mechanism for most significant compromises, and ransomware in particular is the event most likely to interrupt a service organization's ability to serve its customers at all. Unauthorized software also introduces vulnerabilities the organization does not know it has.

HOW TO AUDIT IT

1. Verify malware protection coverage across the in-scope estate from tooling reports, including servers and non-standard systems.
2. Check currency separately from coverage, identifying agents that have not updated recently.
3. Confirm protection cannot be disabled by ordinary users.
4. Review detections during the period and confirm each received a response.
5. Check controls preventing unauthorized software installation and whether users hold rights to install.
6. Verify protection at the entry points: email, web, and removable media.
7. Assess backup isolation, since it determines whether a ransomware event is recoverable.

EVIDENCE TO COLLECT

- Malware protection coverage and update status reports across the period
- Tamper protection configuration
- Detection records with response actions and dates
- Application control or installation restriction configuration
- Installed software inventory against approved software
- Backup isolation evidence

HOW TO DOCUMENT IT

Report coverage and currency as separate figures, since a deployed agent that has not updated in months provides little protection and a combined figure conceals it. Record backup isolation specifically: whether backups can be reached and deleted using credentials available in production.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of systems supporting the in-scope services have no malware protection or have not received updates for a stated period, and backups are reachable from the production environment, so a ransomware event would also destroy the means of recovery.

CC7.1 Detecting configuration changes and vulnerabilities

WHAT THE CRITERION ASKS FOR

To meet its objectives, the organization uses detection and monitoring procedures to identify changes to configurations that result in the introduction of new vulnerabilities, and susceptibilities to newly discovered vulnerabilities.

WHY IT EXISTS

Systems drift from their intended configuration continuously, and new vulnerabilities are disclosed in software the organization already runs. Both create exposure without anyone doing anything. This criterion covers the two mechanisms that make that exposure visible: configuration monitoring and vulnerability identification.

HOW TO AUDIT IT

1. Confirm documented configuration standards exist for the technology types in scope and check their source.
2. Verify configuration monitoring operates continuously and detects drift, rather than being a periodic manual check.
3. Compare a sampled live system against its own baseline yourself and record each deviation.
4. Verify vulnerability scanning coverage against the in-scope system inventory and identify systems never scanned.
5. Check whether scanning is authenticated, since unauthenticated scanning substantially understates exposure.
6. Confirm scanning operated at the stated frequency throughout the period.
7. Check that identified vulnerabilities are evaluated for actual exposure rather than accepted at the scanner rating.

EVIDENCE TO COLLECT

- Configuration standards with their source benchmark
- Drift detection configuration and detected drift reports for the period
- Independent configuration extract from a sampled live system
- Scan coverage reconciled to the in-scope system inventory
- Scanner authentication configuration
- Scan records across the period with dates

HOW TO DOCUMENT IT

Perform your own baseline comparison on at least one system and record each deviation, since compliance dashboards in this area are consistently generous. Record scan coverage as a percentage of known in-scope systems and note that unknown systems are excluded from that figure entirely.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of systems supporting the in-scope services are not scanned for vulnerabilities, and independent testing found a stated number of deviations from the organization's own configuration standard on sampled systems.

CC7.2 Monitoring system components for anomalies

WHAT THE CRITERION ASKS FOR

The organization monitors system components and the operation of those components for anomalies indicative of malicious acts, natural disasters, and errors affecting its ability to meet its objectives, and analyzes anomalies to determine whether they represent security events.

WHY IT EXISTS

Monitoring is the detection capability, and detection time is the variable that most determines the eventual cost of an incident. For a service organization, the alternative to detecting your own incidents is having customers detect them for you, which is the worst way for a SOC 2 report to be tested.

HOW TO AUDIT IT

1. Establish what is monitored and confirm coverage matches the systems supporting in-scope services.
2. Verify logging is in place and sufficient to support detection, including privileged activity and authentication events.
3. Check monitoring coverage across hours, since detection operating only in business hours leaves most of the week uncovered.
4. Review alert volumes, triage rates, and outcomes across the period, and identify alerts never triaged.
5. Categorize incidents during the period by how they were detected: internal monitoring, staff, or customer.
6. Verify log retention is sufficient relative to the organization's own detection times.
7. Confirm monitoring operated throughout the period rather than being implemented partway through.

EVIDENCE TO COLLECT

- Monitoring coverage and detection rule inventory
- Log source coverage against the in-scope system inventory
- Alert volume, triage, and outcome statistics for the period
- Out of hours coverage arrangements or rota
- Incident records showing detection source
- Log retention configuration

HOW TO DOCUMENT IT

Calculate the proportion of incidents detected internally versus externally, which is the single most useful measure of this criterion and is rarely computed by the organization itself. Present alert volume against triage rate with the gap stated.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of the incidents recorded during the period were identified by customers rather than by the organization's own monitoring, and no detection capability operates outside business hours.

CC7.3 Evaluating security events

WHAT THE CRITERION ASKS FOR

The organization evaluates security events to determine whether they could or have resulted in a failure to meet objectives, and if so takes action to prevent or address such failures.

WHY IT EXISTS

The volume of events far exceeds the volume of real incidents, and the triage decision determines whether anything happens. Under-classification means real attacks are dismissed as noise, and that dismissal is invisible unless someone reviews it independently.

HOW TO AUDIT IT

1. Obtain the event classification criteria and confirm they are specific enough to apply consistently.
2. Sample events evaluated and not escalated during the period, and independently assess a subset.
3. Confirm evaluation decisions are recorded with reasoning and an identifiable decision maker.
4. Measure the interval between detection and evaluation across the period.
5. Check evaluator competence and out of hours coverage.
6. Identify any event evaluated as non-reportable that later proved to be an incident, and check whether that was reviewed.

EVIDENCE TO COLLECT

- Event classification criteria and severity definitions
- Event population for the period with evaluation outcomes and decision makers
- Detection and evaluation timestamps
- Escalation records
- Evaluator competence and coverage arrangements

HOW TO DOCUMENT IT

Present your independent reassessment as a table of event, organizational decision, your decision, and the basis for disagreement, with the disagreement rate stated. Record evaluation intervals as a distribution rather than an average, since the slow tail is what matters.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security events were dismissed without recorded reasoning, and independent review of a sample found a stated number that should have been treated as incidents affecting customer data.

CC7.4 Responding to identified security incidents

WHAT THE CRITERION ASKS FOR

The organization responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents as appropriate.

WHY IT EXISTS

A plan that is not followed provides no protection, and improvised response produces inconsistent containment and lost evidence. For a service organization the communication element carries contractual weight, because customer notification timeframes are usually written into agreements.

HOW TO AUDIT IT

1. Obtain the incident response programme and confirm it defines roles, authorities, and escalation paths.
2. Select incidents from the period across severities and reconstruct the response from records.
3. Compare actual response against the documented programme and identify deviations.
4. Measure detection to response, response to containment, and containment to resolution intervals.
5. Verify customer notification occurred where required, comparing timing to contractual commitments.
6. Check that records were made during the incident rather than reconstructed afterwards, by examining timestamps.
7. Confirm the programme was exercised during the period if no real incident occurred, and review the exercise results.

EVIDENCE TO COLLECT

- Incident response programme with roles and escalation
- Incident records for the period with full timelines
- Contemporaneous notes or ticket updates with timestamps
- Customer notification records against contractual timeframes
- Containment and remediation evidence
- Exercise records where no incident occurred

HOW TO DOCUMENT IT

Build a timeline per sampled incident with elapsed intervals calculated. Record customer notification timing against the contractual requirement explicitly, since a missed contractual notification is both a control exception and a breach of agreement and should be reported as both.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer notification following a security incident during the period occurred a stated number of days after the contractual requirement, and incident response was not recorded as it happened, so the organization cannot demonstrate what actions it took.

CC7.5 Recovering from identified security incidents

WHAT THE CRITERION ASKS FOR

The organization identifies, develops, and implements activities to recover from identified security incidents. Recovery covers restoring normal operation and addressing the underlying cause so the incident does not recur.

WHY IT EXISTS

Response contains an incident; recovery restores the service and prevents repetition. Recurrence is the clearest evidence that recovery is incomplete, and it is the easiest thing for an auditor to demonstrate across a period.

HOW TO AUDIT IT

1. Verify post-incident review is performed with defined criteria for which incidents warrant one.
2. Assess whether reviews identify underlying causes rather than restating what happened.
3. Verify actions arising have owners and dates, and check completion against those dates.
4. Analyze recurrence across the period by grouping incidents by cause.
5. Check whether learning crossed boundaries, so that an issue found in one system prompted checks of similar systems.
6. Verify recovery capability itself, including whether restoration has been tested rather than assumed.
7. Confirm incidents were formally closed with documented resolution.

EVIDENCE TO COLLECT

- Post-incident review reports with cause analysis
- Action registers with owners, dates, and status
- Incident data for the period categorized by cause
- Restoration test records
- Evidence of control or procedure changes made following incidents

HOW TO DOCUMENT IT

Present recurrence analysis as a count of incidents by cause across the period; repetition is the most persuasive evidence available for this criterion. Record where a stated cause is a symptom, such as human error, since that indicates analysis stopped early.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of incidents during the period shared the same underlying cause as earlier incidents, indicating that response is effective but recovery does not address why the incidents happen.

CC8.1 Change management

WHAT THE CRITERION ASKS FOR

The organization authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives. This single criterion covers the whole change lifecycle.

WHY IT EXISTS

Change is the most common cause of both outage and newly introduced vulnerability. For a Type 2, change management also produces one of the cleanest testable populations: every production change during the period should have authorization, testing, and approval behind it.

HOW TO AUDIT IT

1. Establish the complete population of production changes during the period from system deployment records rather than from the ticket system.
2. Reconcile that population against the change records and report changes made outside the process.
3. Sample changes and verify authorization, testing, and approval, checking evidence rather than status fields.
4. Confirm the approver is independent of the developer. Self-approval is a common and significant exception.
5. Examine emergency changes separately: their volume, their retrospective approval, and whether review followed.
6. Verify separation of development, test, and production environments and check who can deploy to production.
7. Check that rollback capability exists and whether it has been used or tested.

EVIDENCE TO COLLECT

- Complete population of production changes from deployment logs
- Change records with authorization, test evidence, and approval for the sample
- Emergency change records with retrospective review
- Deployment permission listings for production
- Environment separation evidence
- Rollback records

HOW TO DOCUMENT IT

Establish the change population from deployment logs and reconcile to the change record, since this comparison reveals change occurring outside the process and organizations rarely perform it themselves. Report emergency changes as a proportion of total, since a high proportion means the emergency route has become the normal route.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of production changes during the period occurred outside the change management process, and a stated number were approved by the same individual who developed them. Both figures derive from the organization's own systems.

CC9.1 Risk mitigation activities for business disruptions

WHAT THE CRITERION ASKS FOR

The organization identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions. This covers continuity and recovery capability, and the insurance or other arrangements supporting it.

WHY IT EXISTS

Availability commitments to customers depend on the ability to keep operating through disruption. Where availability is in scope this criterion is central; where it is not, it still matters because a disruption affecting security controls creates exposure.

HOW TO AUDIT IT

1. Obtain the business impact analysis and recovery objectives, and confirm they were set by the business rather than by technology.
2. Compare stated recovery objectives against demonstrated capability from actual test results, not design documents.
3. Review continuity and recovery testing during the period, including scope, realism, and outcomes.
4. Distinguish backup completion from restoration testing rigorously; organizations routinely present the first as the second.
5. Check whether security controls are maintained during disruption, including whether the recovery environment matches production.
6. Verify dependencies were considered, including on subservice organizations.
7. Check insurance arrangements where relied on as mitigation.

EVIDENCE TO COLLECT

- Business impact analysis with recovery objectives
- Continuity and recovery test records with dates and measured outcomes
- Restoration evidence distinct from backup completion reports
- Recovery environment control comparison against production
- Subservice organization continuity arrangements
- Insurance policies where relied upon

HOW TO DOCUMENT IT

Present a table of critical service, required recovery time, last demonstrated recovery time, and last test date. Blank cells in the demonstrated column are the finding and usually outnumber the filled ones. State explicitly where backup completion was offered as evidence of restoration capability.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has never demonstrated that it can restore a stated number of the services covered by its availability commitments within the committed timeframes, and for several the capability has never been tested.

CC9.2 Managing vendor and business partner risk

WHAT THE CRITERION ASKS FOR

The organization assesses and manages risks associated with vendors and business partners. This covers assessment before engagement, contractual requirements, and ongoing monitoring, including subservice organizations whose controls the organization relies on.

WHY IT EXISTS

Vendors extend the organization's control environment into organizations it does not control. For SOC 2 specifically, subservice organizations are the ones whose failures land directly in the organization's report, and complementary user entity controls place obligations back on the organization that are routinely unread.

HOW TO AUDIT IT

1. Obtain the vendor register and test completeness against accounts payable for the period, since procurement-based registers miss vendors engaged by business units directly.
2. Verify vendors are assessed before engagement with depth proportionate to risk.
3. Distinguish subservice organizations from other vendors and confirm the carve-out or inclusive treatment is correctly applied and disclosed.
4. For subservice organizations, obtain their reports covering the period and check for gaps in coverage dates.
5. Verify exceptions and carve-outs in those reports were assessed rather than accepted with the overall opinion.
6. Confirm complementary user entity controls identified in those reports have been implemented by the organization.
7. Check contractual security requirements, including notification obligations and audit rights.

EVIDENCE TO COLLECT

- Vendor register reconciled to accounts payable for the period
- Vendor risk assessments with dates against engagement dates
- Subservice organization reports covering the full period
- Analysis of exceptions and carve-outs in those reports
- Complementary user entity control implementation evidence
- Contracts containing security and notification requirements

HOW TO DOCUMENT IT

Check subservice organization report coverage dates against your period and record any gap, since a gap requires additional procedures and is frequently missed. Record complementary user entity controls individually with implementation status, because these are obligations placed on the organization and unimplemented ones affect the reliance the report supports.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the subservice organization report relied upon does not cover a stated number of months of the period, and a stated number of complementary user entity controls it identifies have not been implemented by the organization. Both affect the assurance the report can provide and should be raised before the opinion is drafted.

CHAPTER 2

The Additional Categories: Availability, Confidentiality, Processing Integrity, Privacy

Four entries, one per category, summarizing the twenty-eight criteria outside the common criteria. These are covered at category level rather than criterion by criterion, because most engagements include one or two of them and covering all twenty-eight in full would triple the length of this guide for material most readers will not use.

The important thing to understand about these categories is that they are additive, not alternative. The common criteria apply to every SOC 2 engagement regardless of which categories are included. Adding Availability does not replace anything; it adds three criteria on top of the thirty-three you already have. Choose categories based on the commitments the organization has actually made to its customers, not on which sound impressive. A category included without a corresponding commitment adds testing burden and creates an obligation the organization did not need to take on. Conversely, a commitment made in customer agreements with no corresponding category in the report is a gap customers will notice.

Privacy deserves particular caution. It is by far the largest of the four, at eighteen criteria, and it is the only one that constrains what may be collected and how long it may be kept rather than how it is protected. Organizations frequently include it believing it is a privacy-flavoured extension of confidentiality. It is not, and if you are scoping an engagement that includes it, budget for it accordingly.

Quick reference: Additional Categories

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
A1 cyb	Availability	Capacity monitoring configuration, thresholds, and trend reporting for the period
C1	Confidentiality	Classification scheme with criteria and handling requirements per level
PI1	Processing Integrity	Documented processing objectives and specifications
P1	Privacy	Privacy notice and record of processing activities for comparison

A1 Availability

WHAT THE CRITERION ASKS FOR

Three criteria (A1.1 to A1.3) covering capacity, environmental protections, and recovery. A1.1 requires capacity to be maintained, monitored, and evaluated against demand. A1.2 requires environmental protections, software, data backup processes, and recovery infrastructure to be authorized, designed, developed, implemented, operated, approved, maintained, and monitored. A1.3 requires recovery plan procedures to be tested.

WHY IT EXISTS

Availability is included when the organization has made uptime or continuity commitments to customers. The distinguishing feature of this category is A1.3: it requires testing, not merely capability. An untested recovery plan is an assumption, and this is the only place in the trust services criteria where testing is explicitly demanded.

HOW TO AUDIT IT

1. For A1.1, obtain capacity monitoring configuration with thresholds, and check forecasting exists rather than reaction at the point of exhaustion. Review capacity-related incidents in the period for predictability.
2. For A1.2, verify backup configuration and success rates across the period, and examine environmental protections at any organization-controlled facility including power, cooling, and fire suppression, with test records.
3. For A1.2, assess backup isolation specifically: whether backups can be reached and deleted using credentials available in production.
4. For A1.3, obtain recovery test records with dates, scope, and measured outcomes. Distinguish restoration testing from backup completion reporting.
5. For A1.3, compare demonstrated recovery times against the commitments made to customers, and identify services never tested.
6. Trace dependencies that defeat apparent redundancy: shared power, shared network paths, shared authentication.
7. Confirm all three criteria operated throughout the period rather than at a point in time.

EVIDENCE TO COLLECT

- Capacity monitoring configuration, thresholds, and trend reporting for the period
- Backup job success and failure reports across the period
- Backup isolation and immutability configuration
- Recovery test records with dates, scope, and measured recovery times
- Environmental protection test records for organization-controlled facilities
- Customer availability commitments for comparison
- Subservice organization reports covering hosted infrastructure

HOW TO DOCUMENT IT

Present a table of committed service, required recovery time, last demonstrated recovery time, and last test date. Blank cells in the demonstrated column carry this category. Record backup isolation as a specific technical assessment rather than as a general observation, and state clearly wherever backup completion was offered as evidence of restoration capability.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has never tested restoration for a stated number of services covered

by availability commitments to customers, and its backups can be deleted using credentials available in the production environment. Where the category is sound, say so; a working recovery regime is worth stating positively in a report customers will read.

C1 Confidentiality

WHAT THE CRITERION ASKS FOR

Two criteria. C1.1 requires the organization to identify and maintain confidential information to meet its objectives. C1.2 requires it to dispose of confidential information to meet those objectives. Together they cover the lifecycle of information the organization has committed to keep confidential.

WHY IT EXISTS

Confidentiality is included when the organization has made confidentiality commitments beyond security generally, typically in customer agreements. The category is short but the disposal criterion carries real weight, because retained information the organization committed to destroy is a breach of agreement independent of any security failure.

HOW TO AUDIT IT

1. For C1.1, establish how confidential information is identified, including whether a classification scheme exists and is applied consistently.
2. For C1.1, verify protection is commensurate with the confidentiality commitments made, by comparing controls to a sample of customer agreements.
3. For C1.1, test whether identification actually occurs, by sampling information assets and independently assessing their classification.
4. For C1.2, obtain retention requirements derived from commitments and verify disposal occurs at their expiry.
5. For C1.2, test by querying for data that should no longer exist rather than by reviewing the disposal procedure.
6. For C1.2, check whether disposal reaches all copies including backups, archives, and non-production environments.
7. Verify disposal is evidenced, since an unrecorded deletion cannot be demonstrated to a customer.

EVIDENCE TO COLLECT

- Classification scheme with criteria and handling requirements per level
- Customer agreements containing confidentiality and return or destruction commitments
- Retention schedule derived from those commitments
- Query evidence demonstrating presence or absence of expired data
- Disposal records with dates for the period
- Backup and non-production environment disposal arrangements

HOW TO DOCUMENT IT

Test disposal by querying for data past its retention limit and record the oldest record found in each sampled category against its limit. Address backups explicitly, since disposal from production with retention in backup is the common partial implementation and organizations frequently believe it satisfies the commitment.

EXECUTIVE SUMMARY TREATMENT

Suggested language: customer information that the organization committed to destroy remains in production systems and backups, the oldest exceeding its commitment by a stated period. State the number of customers affected, since this is a contractual exposure as well as a control exception.

PI1 Processing Integrity

WHAT THE CRITERION ASKS FOR

Five criteria (PI1.1 to PI1.5) covering the completeness, validity, accuracy, timeliness, and authorization of processing. PI1.1 addresses information about processing objectives. PI1.2 covers inputs. PI1.3 covers processing itself. PI1.4 covers outputs. PI1.5 covers storage of inputs, items in processing, and outputs.

WHY IT EXISTS

Processing integrity is included when the organization has committed that its processing is complete, valid, accurate, timely, and authorized. It is the least commonly included category and the most commonly misunderstood: it concerns whether processing does what it is supposed to, not whether it is secure. A perfectly secure system can process incorrectly.

HOW TO AUDIT IT

1. For PI1.1, obtain the definitions of processing objectives and confirm they are specific enough to test against, and that they are communicated to users.
2. For PI1.2, examine input controls including validation, completeness checking, and authorization, and test whether invalid input is actually rejected.
3. For PI1.3, test processing accuracy by tracing transactions end to end and reperforming calculations independently.
4. For PI1.3 and PI1.4, examine error handling: how processing exceptions are identified, corrected, and reprocessed, and whether any are simply dropped.
5. For PI1.4, verify output completeness and accuracy controls, including reconciliation between input and output volumes.
6. For PI1.5, check that stored inputs, items in process, and outputs are protected against alteration and loss.
7. Across all five, obtain the error and exception population for the period and check that each was resolved.

EVIDENCE TO COLLECT

- Documented processing objectives and specifications
- Input validation configuration and rejection test results
- Transaction samples traced end to end with independent reperformance
- Reconciliation records between input and output volumes for the period
- Error and exception logs with resolution records
- Storage integrity controls for items in process

HOW TO DOCUMENT IT

Reperform processing independently for a sample of transactions and record your result against the system's, since this is the only test that directly addresses the category. Present the error population with resolution status, and identify any errors that were dropped rather than resolved, which is the most consequential finding available here.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of processing errors during the period were not resolved, and independent reperformance of a sample of transactions produced results differing from the system output in a stated number of cases. Both go directly to the commitment the category covers.

P1 Privacy

WHAT THE CRITERION ASKS FOR

Eighteen criteria across eight series covering the lifecycle of personal information: notice and communication of objectives (P1), choice and consent (P2), collection (P3), use, retention and disposal (P4), access (P5), disclosure and notification (P6), quality (P7), and monitoring and enforcement (P8). It is by a wide margin the largest additional category.

WHY IT EXISTS

Privacy is included when the organization handles personal information on its own behalf or makes privacy commitments to customers. It is the only category that constrains what the organization may collect and how long it may keep it, which are not security questions at all. P6 in particular carries direct regulatory weight, covering disclosure to third parties and breach notification.

HOW TO AUDIT IT

1. For P1, obtain the privacy notice and verify it accurately describes actual practice, comparing it to the record of processing activities rather than accepting it.
2. For P2, examine consent mechanisms where consent is relied on, including whether it can be withdrawn and whether withdrawal is honoured.
3. For P3, test collection against the stated purposes and assess whether data collected exceeds what those purposes require.
4. For P4, verify retention periods are applied in practice by querying for data past its limit, and check disposal reaches backups and non-production environments.
5. For P5, test the data subject access process end to end if a real request exists, measuring response time against the applicable statutory deadline.
6. For P6, examine third-party disclosures and the agreements governing them, and test the breach notification process against any incident in the period.
7. For P7 and P8, check accuracy and correction controls over personal information, and verify privacy compliance monitoring occurs and identified issues are addressed.

EVIDENCE TO COLLECT

- Privacy notice and record of processing activities for comparison
- Consent records and withdrawal mechanism evidence
- Data inventory showing collection against stated purposes
- Retention configuration and query evidence for expired data
- Data subject request log with response times against statutory deadlines
- Third-party disclosure agreements and transfer mechanisms
- Breach notification records with timing, and privacy compliance monitoring records for the period

HOW TO DOCUMENT IT

This category needs its own workpaper section rather than being folded into the others. Record request response times against the statutory deadline, since that is directly measurable and directly penalizable, and list data fields captured against stated purpose to identify those serving none. Note any processing with no identified lawful basis, which is definitive.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's privacy notice does not accurately describe its actual processing, and personal information is retained beyond the periods the notice states. Name regulatory penalty exposure

explicitly here, since for this category it is quantifiable in a way it is not for the others.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Assertion

Management's written statement that the description is accurate and the controls were suitably designed and, for a Type 2, operating effectively. The auditor opines on the assertion; management makes it. An engagement cannot proceed without one.

Carve-out method

A treatment of subservice organizations in which their controls are excluded from the description and the auditor's opinion. The alternative is the inclusive method, which brings them in. Carve-out is far more common. Which method was used must be disclosed, and readers frequently miss it.

Common criteria

The thirty-three criteria (CC1.1 to CC9.2) that apply to every SOC 2 engagement regardless of which trust services categories are included. They map to the COSO internal control framework for CC1 to CC5 and to security-specific matters for CC6 to CC9.

Complementary subservice organization control

A control the subservice organization must perform for the service organization's controls to achieve their objectives. Usually shortened to CSOC.

Complementary user entity control

A control the customer must perform for the service organization's controls to achieve their objectives. Usually shortened to CUEC. These place obligations on the reader of the report, and are routinely unread. A CUEC never communicated to customers cannot be relied upon.

Criterion

A required attribute of the system, stated in the trust services criteria. Note that criteria are not controls. The organization designs its own controls to meet the criteria, which is the structural difference between SOC 2 and a prescriptive control framework.

Description criteria

The separate criteria (DC section) governing whether management's description of the system is presented fairly. Distinct from the trust services criteria, which govern the controls. Both are opined on.

Deviation

An instance where a control did not operate as described. Also called an exception. Not every deviation results in a qualified opinion; severity and pervasiveness determine that.

Inclusive method

A treatment of subservice organizations in which their controls are included in the description and the auditor's opinion. Requires their cooperation and their own assertion.

Period

The span of time a Type 2 report covers, typically between three and twelve months. Controls must be

shown to have operated throughout it, which is why populations and dates matter far more in a Type 2 than in a Type 1.

Points of focus

Illustrative considerations accompanying each criterion, revised in 2022. They are not requirements and need not be addressed individually, but they indicate what the criterion is reaching for and are useful when a criterion's wording seems abstract.

Population

The complete set of items from which a sample is drawn. Establishing it independently, usually from system logs rather than from a maintained list, is the single most important step in Type 2 testing. A perfect sample of an incomplete population tests nothing.

Qualified opinion

An opinion stating that, except for specified matters, the controls met the criteria. An adverse opinion states they did not. A disclaimer states the auditor could not form an opinion at all.

Service auditor

The independent practitioner who performs the examination and issues the report. Distinct from the user auditor, who audits the customer and reads the report as evidence.

Service organization

The entity providing services to customers, whose controls are being examined. Its customers are user entities.

Subservice organization

A vendor whose own controls are necessary for the service organization to meet the criteria. Cloud hosting providers are the usual example. Treated by either carve-out or inclusive method.

Test of design

An assessment of whether a control, as constructed, would meet the criterion if it operated. A Type 1 tests design only. A control can be well designed and never performed.

Test of operating effectiveness

An assessment of whether a control actually operated as described throughout the period. Only performed in a Type 2, and requires evidence across the period rather than at a point in time.

Trust services categories

The five categories: Security, Availability, Confidentiality, Processing Integrity, and Privacy. Security is always included and is what the common criteria address. The other four are additive and are selected based on the commitments made to customers.

Type 1

A report on the fairness of the description and the suitability of control design at a specified date. No operating effectiveness testing. Faster and cheaper, and correspondingly less useful to customers.

Type 2

A report on the fairness of the description, the suitability of control design, and the operating effectiveness of controls throughout a specified period. This is what customers normally mean when they ask for a SOC 2.

User entity

A customer of the service organization, and the intended reader of the report.

Workpaper

The auditor's record of what was tested, how, what was found, and what was concluded. Written so a reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- Accountability for internal control responsibilities, 7
- Assertion, 43
- Authorizing, modifying and removing access, 22
- Availability, 37
- Board independence and oversight, 4
- Carve-out method, 43
- Change management, 33
- Commitment to competence, 6
- Commitment to integrity and ethical values, 3
- Common criteria, 43
- Complementary subservice organization control, 43
- Complementary user entity control, 43
- Confidentiality, 39
- Considering the potential for fraud, 13
- Criterion, 43
- Deploying controls through policies and procedures, 19
- Description criteria, 43
- Detecting configuration changes and vulnerabilities, 28
- Deviation, 43
- Discontinuing protections over disposed assets, 24
- Evaluating and communicating deficiencies, 16
- Evaluating security events, 30
- External communication, 10
- Identifying and analyzing risk, 12
- Identifying and assessing changes, 14
- Inclusive method, 43
- Internal communication of objectives and responsibilities, 9
- Logical access measures against external threats, 25
- Logical access security software and infrastructure, 20
- Managing vendor and business partner risk, 35
- Monitoring system components for anomalies, 29
- Obtaining and using relevant quality information, 8
- Ongoing and separate evaluations, 15
- Period, 43
- Points of focus, 44
- Population, 44
- Preventing and detecting unauthorized software, 27
- Privacy, 41
- Processing Integrity, 40
- Qualified opinion, 44
- Recovering from identified security incidents, 32
- Registration and authorization of new users, 21
- Responding to identified security incidents, 31
- Restricting physical access, 23
- Restricting transmission, movement and removal of information, 26
- Risk mitigation activities for business disruptions, 34
- Selecting and developing control activities, 17
- Selecting and developing technology general controls, 18
- Service auditor, 44
- Service organization, 44
- Specifying objectives, 11
- Structures, reporting lines, authorities and responsibilities, 5
- Subservice organization, 44
- Test of design, 44
- Test of operating effectiveness, 44
- Trust services categories, 44
- Type 1, 44
- Type 2, 44
- User entity, 44
- Workpaper, 45